

FLAWFIX SECUREASSIST

Automated Vulnerability Detection, Semantic LLVM IR Analysis & Patch Verification Audit Report

Target File: test1.py	Language: PYTHON
Project: FlawFix Workspace	Audit Date: 2026-09-02 15:14:45
Report ID: RPT-46B7ED65	Engine: FlawFix LLVM+XAI v1.0

1. Executive Security Assessment

The analyzed Python script contains a High severity OS Command Injection vulnerability (CWE-78) in the ping_host function due to direct concatenation of unvalidated user input into a shell command executed via os.system.

TOTAL FLAWS	CRITICAL	HIGH	MEDIUM	LOW
1	0	1	0	0

2. Detected Vulnerability Inventory

ID	Classification (CWE)	Severity	Function	Lines
VULN-001	CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') OS Command Injection in ping_host via os.system	HIGH	@ping_host	5, 6

3. Explainable AI (XAI) Diagnostic Details

Finding 1: OS Command Injection in ping_host via os.system (CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection'))

Root Cause: The ping_host function accepts unsanitized input via input() and concatenates it directly into a string executed by os.system(). Because os.system spawns a system shell, metacharacters such as ';', '&', '|', or backticks in the input string allow attackers to execute arbitrary shell commands.

Security Exploit Impact: An attacker providing crafted input can execute arbitrary operating system commands with the privilege level of the running Python process, potentially leading to host compromise, privilege escalation, or unauthorized access to system resources.

Remediation Guideline: Avoid using os.system for executing system utilities. Instead, use Python's subprocess module with argument sequences (shell=False) and validate input parameters prior to invocation.

AI-Generated Secure Patch: *Subprocess Argument List Execution with IP Validation*

```
import subprocess
import ipaddress

def ping_host():
    host = input("Enter host: ").strip()
    try:
        ipaddress.ip_address(host)
        subprocess.run(["ping", "-c", "1", host], check=True)
    except ValueError:
        print("Invalid host IP address.")

if __name__ == "__main__":
    ping_host()
```

Optimization Notes: Bypasses the system shell interpreter completely, removing shell overhead and preventing command injection.

5. AI Code Optimization Recommendations

- **Decouple User Input from Business Logic:** Separate console I/O from execution logic by accepting the host string as a function parameter. *(Impact: Improves unit testing capability, reusability, and maintainability.)*